

LIFE AFTER MFA

How MFA is no longer enough



{**elysium**security}
cyber protection & response

Version: 1.2

Author: Sylvain Martinez

Classification: **PUBLIC**

MFA remains one of the most effective security controls available. Yet a growing share of account takeovers happen on accounts that have it. This session explains how attackers get past MFA, and which controls take each route away from them.

1. CONTEXT:

What MFA proves, and what it does not

2. GET IN:

Around, through, after and reset

3. GET OUT:

One set of controls per route, plus eviction

4. TAKEAWAYS:

What to remember, and what to do

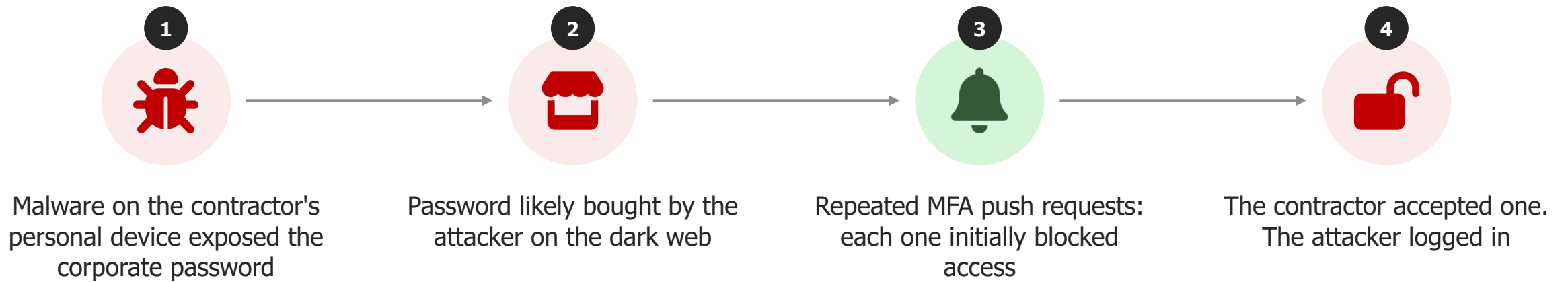


CONTEXT

GET IN

GET OUT

TAKEAWAYS



The password was already lost. MFA was the last control left, and it relied on a person saying no every single time.



99.22%

reduction in the risk of account compromise across the studied population

Microsoft Research, May 2023



98.56%

risk reduction even for accounts whose credentials had already leaked

Microsoft Research, May 2023



>97%

of identity attacks are password attacks, the attacks MFA is built to stop

Microsoft Digital Defense Report, Oct 2025

✓ **MFA is still a relevant control. It is where attackers go now that MFA has become common.**

59%

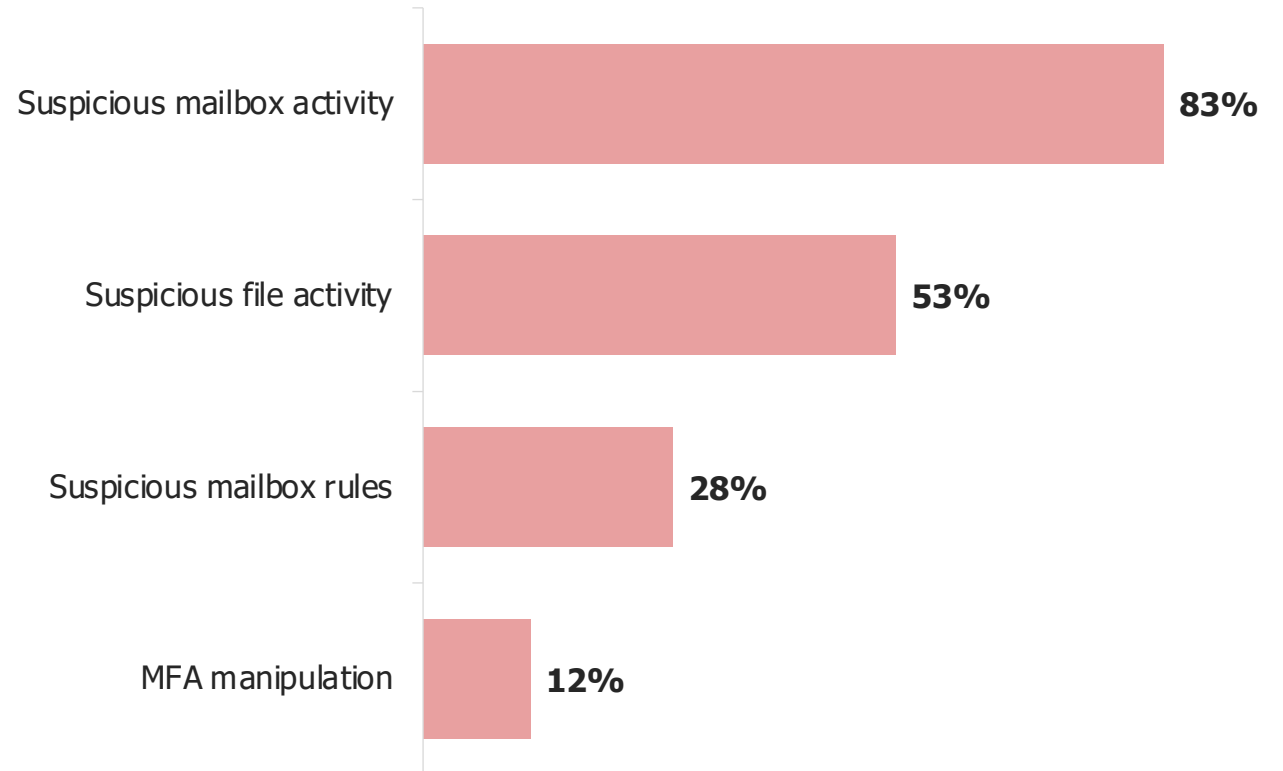
of accounts taken over had MFA enabled

Proofpoint: 50M+ cloud accounts, Nov 2024 – Nov 2025

99% of organisations targeted by account takeover

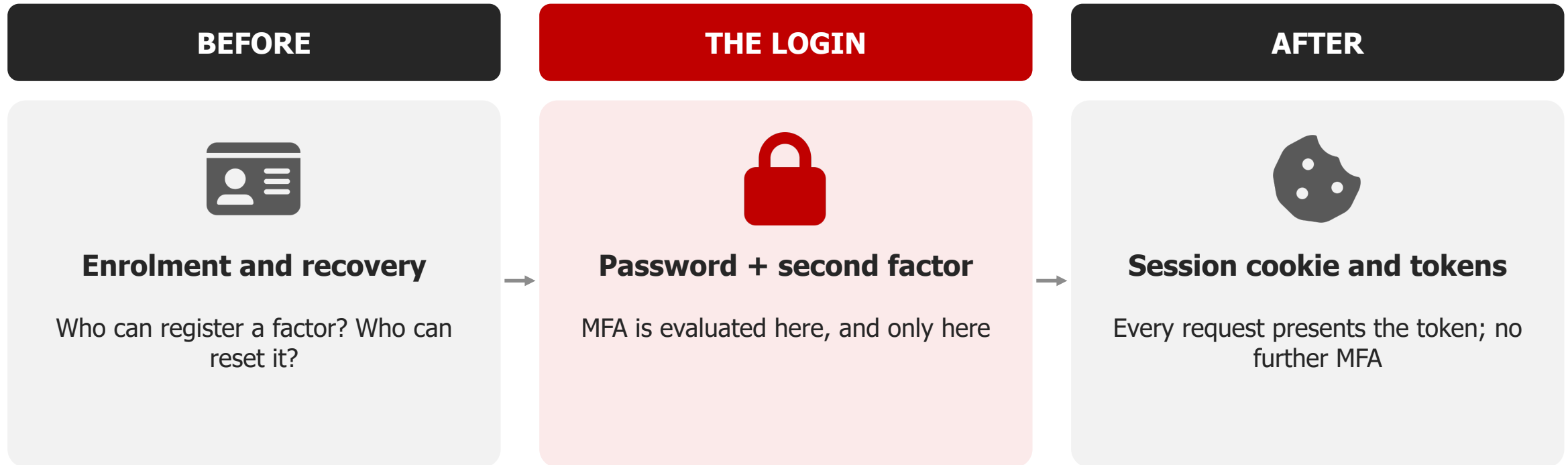
67% had at least one successful takeover

After takeover: what usually happens



Reference: Proofpoint 2026 report

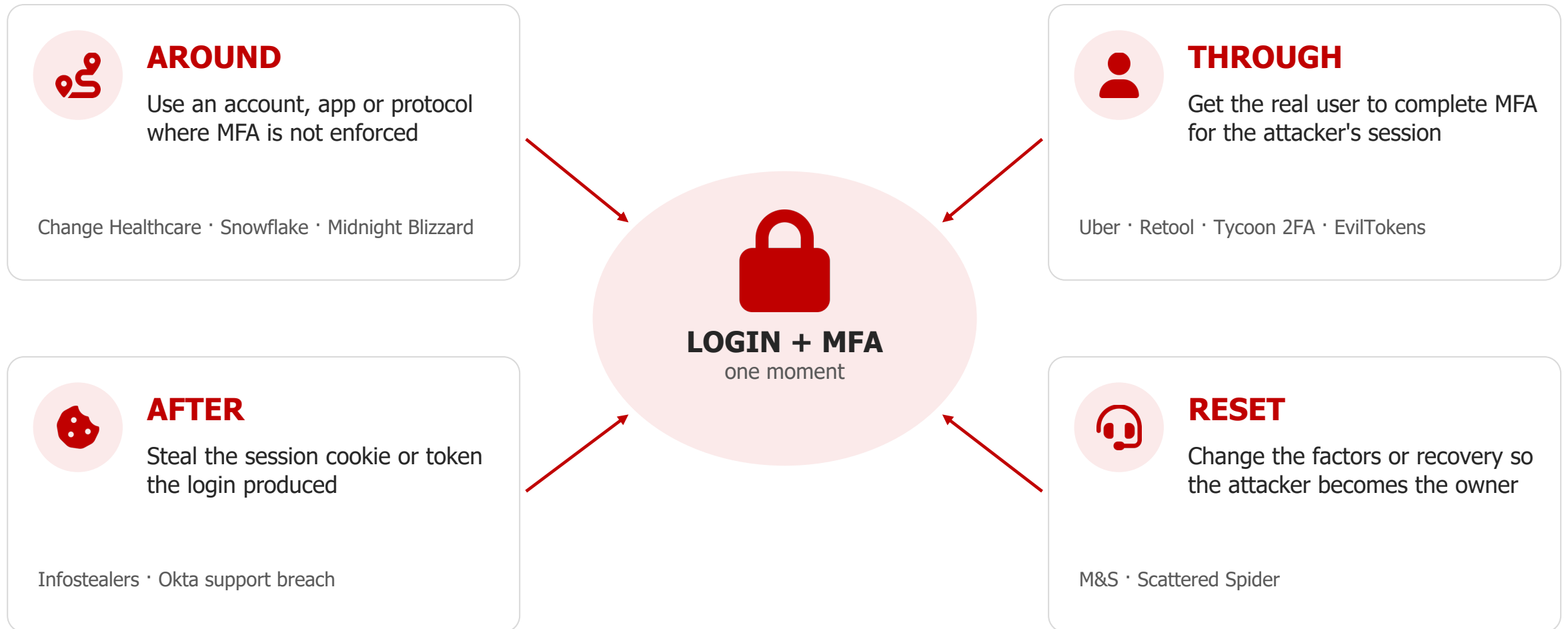
<https://www.elysiumsecurity.com>



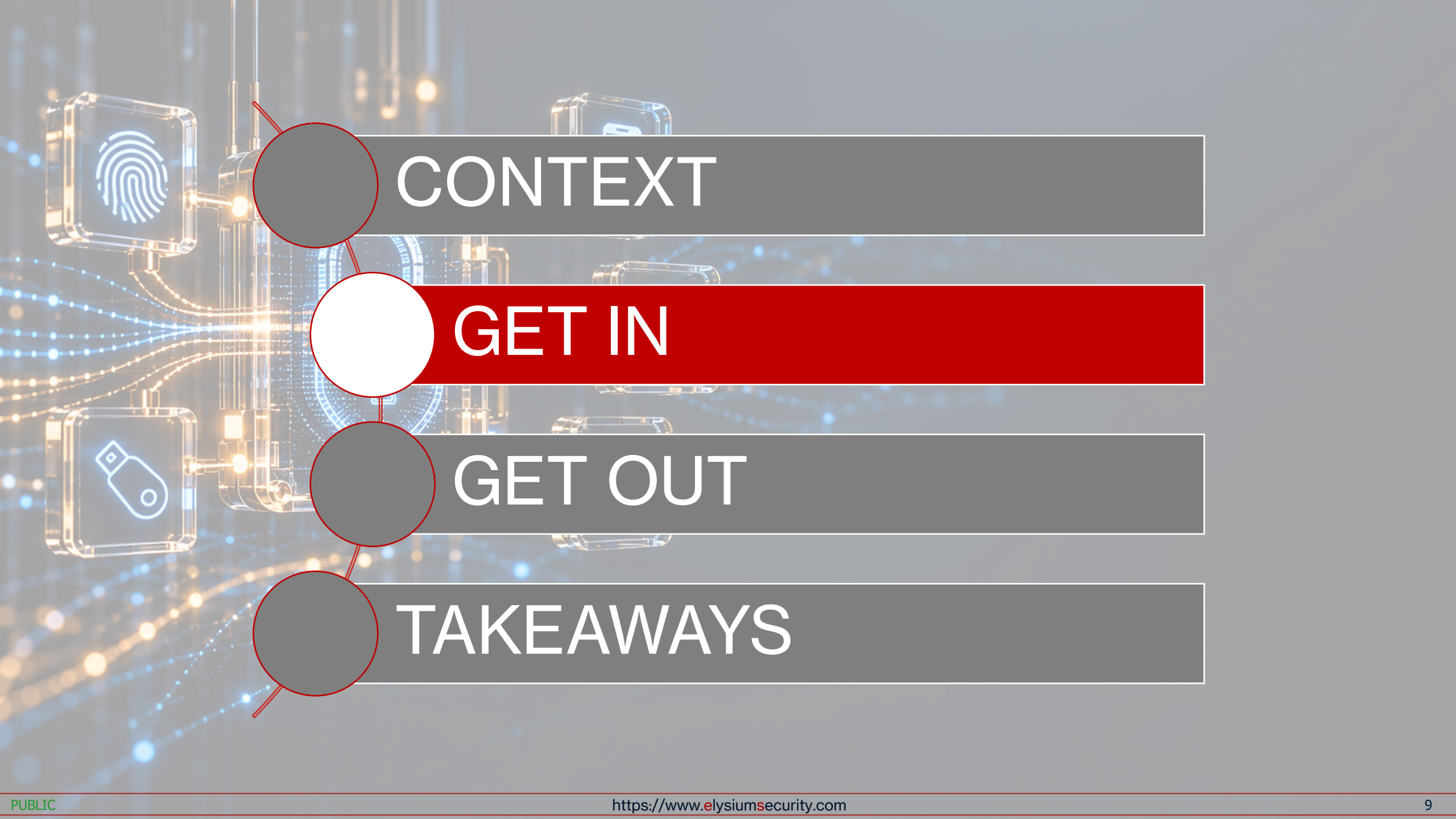
Bearer token: “any party in possession of a bearer token can use it to get access to the associated resources”, without proving possession of a key (RFC 6750). Device-bound tokens change this, where supported.



Whoever holds the session is the user, until it expires or is revoked.



🚩 Only one of these four routes involves defeating MFA itself. The other three avoid it entirely.



CONTEXT

GET IN

GET OUT

TAKEAWAYS

AROUND

THROUGH

AFTER

RESET



Change Healthcare

February 2024

- Stolen credentials used on a Citrix remote-access portal
- "The portal did not have multi-factor authentication." — CEO testimony, May 2024

Gap: Remote access outside MFA

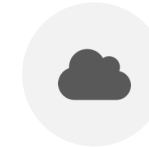


Snowflake customers

2024 · UNC5537

- ~165 organisations notified
- $\geq 79.7\%$ of accounts used had prior credential exposure, some via infostealer logs dating to 2020

Gap: Accounts without MFA; credentials never rotated



Microsoft

Detected January 2024

- Password spray on a legacy, non-production test tenant account
- OAuth applications then used to reach corporate mailboxes

Gap: Forgotten tenant and app outside policy



Many 'MFA bypass' headlines are coverage gaps: an account, system or protocol outside the policy.

AROUND

THROUGH

AFTER

RESET



Legacy protocols

IMAP, POP, SMTP AUTH and other basic-auth paths that cannot prompt for MFA



Remote access not behind the IdP

VPN, VDI and Citrix portals checking passwords directly



Service, test and break-glass accounts

Excluded by design, then forgotten



Policy exclusions

Conditional Access exceptions that quietly became permanent



Third-party access

Contractors, outsourced IT and support providers



Credentials already stolen

Passwords in infostealer logs stay valid until rotated



Measure MFA coverage per sign-in path, not per user.

AROUND

THROUGH

AFTER

RESET



Push fatigue

Gets: Session



Code relay

Gets: Session



AiTM proxy

Gets: Password +
session cookie



Device trust

Gets: Access +
refresh tokens



Consent

Gets: Delegated API
access

Where the user signs in

Real prompt on their own
phone

Nowhere: reads the code
out to a caller

Attacker's look-alike site,
relayed live

**Genuine Microsoft
page**

**Genuine Microsoft
page**

Does the attacker need the password first?

Yes

Yes

No: captured live

No

No

Stopped by phishing-resistant MFA?

Yes

Yes

Yes

No: block the flow

No: control consent



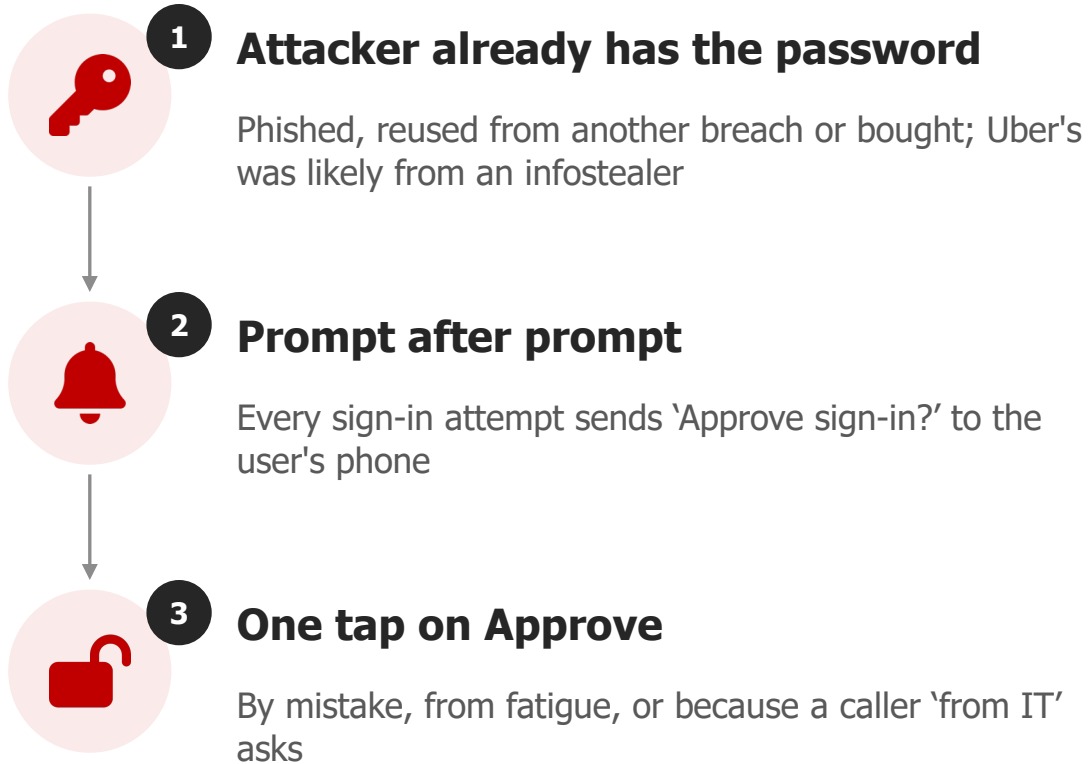
Same outcome, different mechanics: phishing-resistant MFA stops the first three, not device code or consent.

AROUND

THROUGH

AFTER

RESET



Documented

- **Uber, Sep 2022:** repeated prompts "initially blocked access. Eventually, however, the contractor accepted one"
- **Scattered Spider advisory:** repeated prompts until employees pressed 'Accept', "also known as MFA fatigue"



The fix that helps: number matching

- The user must type the number shown on the sign-in screen. Enforced for all Microsoft Authenticator pushes since May 2023
- Stops **blind approvals**; does not stop a caller who reads the number to the victim, or an AiTM page that displays it



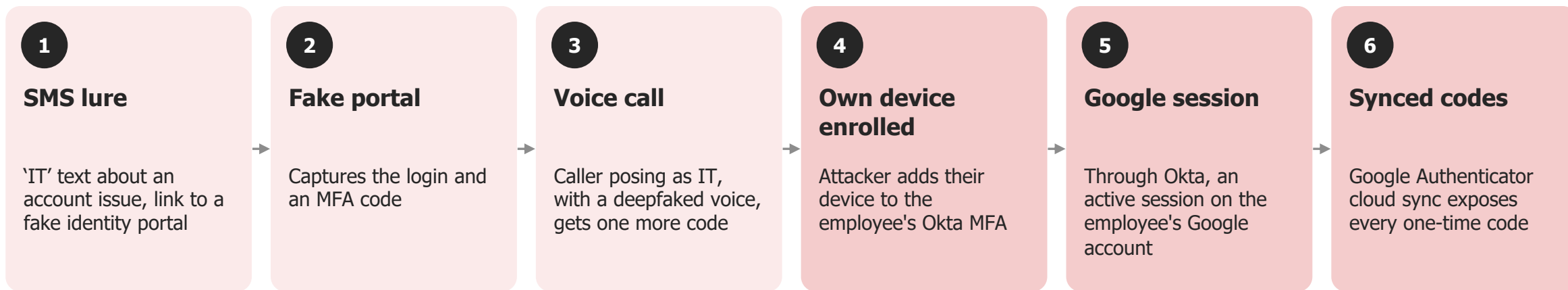
Push fatigue needs no technical skill: just a password and persistence.

AROUND

THROUGH

AFTER

RESET

RELAY: the attacker collects the codes**COLLAPSE: one account unlocks every factor****Why Retool says MFA became single-factor**

MFA was never switched off or faked. The one-time codes for other systems were stored in the same Google account the attacker reached in step 5, so the 'something you have' came with the first compromise.

"Control of the Okta account led to control of the Google account, which led to control of all OTPs stored in Google Authenticator." — Retool

27

cloud customers affected (Retool, September 2023)



MFA was still there. The attacker relayed it once, then enrolled their own.



>10,000

organisations targeted by
one AiTM campaign
(Microsoft, 2022)

~100,000

organisations accessed via
the Tycoon 2FA phishing
kit (Proofpoint, 2026)

Same day

Tycoon 2FA began
recovering after its March
2026 takedown
(CrowdStrike)



The MFA step is just another relayed page. The session cookie at the end reaches the proxy first.

After any of the four routes: persistence • the rogue device

AROUND

THROUGH

AFTER

RESET



● Observed: Storm-2372, EvilTokens ● Research only (2023)

Response action	Effect on this chain
Reset the password	Kills the PRT only if it was obtained with the password. Device and Hello key stay
Revoke sessions	Kills refresh tokens and browser sessions within minutes. Device and Hello key stay
Disable or delete the device	Invalidates the PRT issued on that device
Delete the added Hello key and other methods	Removes what can mint new PRTs



Treat rogue devices and added keys as credentials: revoke sessions, then disable the device and delete the methods.

AROUND

THROUGH

AFTER

RESET

**App requests access**

Malicious app, or a trusted first-party app abused

**User consents or completes sign-in**

On a genuine Microsoft page

**Grant or code handed over**

Delegated access to mail, files, directory

**Password reset**

The grant is still there

ConsentFix Push Security, Dec 2025

- Victim signs in to the genuine Microsoft page for the Azure CLI, a first-party app
- Then pastes the resulting localhost URL, containing an authorisation code, into the attacker's page
- Works even with a passkey: the user authenticated to the real Microsoft

11,290 →
258,033

AI-enabled apps with user consent in Proofpoint's customer base, in under a year. Sprawl hides the bad grant.



Phishing-resistant MFA protects the login. It cannot judge what the user agrees to afterwards.

AROUND

THROUGH

AFTER

RESET



Infection

Cracked software, fake updates, malvertising, often on a personal device

13.2M

infostealer infections recaptured in 2025



Harvest

Cookies, tokens and saved passwords copied from the browser

8.6bn

cookies exposed by those infections



Sale

Logs sold or shared on criminal markets

50

credentials exposed by the average infection



Replay

Attacker loads the session: already past MFA

SpyCloud 2026 Identity Exposure Report

Lumma: 394,000+ infected Windows PCs in two months, before Microsoft, Europol and partners disrupted it in May 2025



A stolen live session cookie has already passed MFA.

AROUND

THROUGH

AFTER

RESET

**Personal Google profile on a managed laptop**

Service-account credentials saved into it

**Attacker accesses the support system**

Most likely via the employee's personal account or device

**HAR files contain session tokens**

Files of 134 customers accessed

**Live admin sessions hijacked**

5 customers affected; no MFA challenge

**Okta's response**

Session token binding to network location for admin sessions · blocking personal Google profiles on managed laptops · added monitoring of the support system



A session token is a password that has already passed MFA. Treat files that contain one accordingly.

AROUND

THROUGH

AFTER

RESET

**M&S**

Attack began April 2025

- Entry through what the chairman called “sophisticated impersonation”, involving a third party
- Reported route: an employee impersonated to obtain a password reset
- Evidence to the UK Business and Trade Committee, 8 July 2025

"As far as I can tell that's a euphemism for impersonation."
Archie Norman, M&S chairman

**Scattered Spider advisory**

FBI, CISA, NCSC-UK and others · updated 29 July 2025



Posed as employees to get IT or the help desk to reset passwords and move MFA to an attacker device



SIM swapping: persuaded carriers to transfer a victim's phone number



Push bombing until a prompt was accepted



Then registered their own MFA tokens for persistence



A help desk can issue a working identity faster than most attackers can phish one.

AROUND

THROUGH

AFTER

RESET

What the attacker adds	Documented example	Removed by a password reset?
Their own MFA method	Scattered Spider advisory (2025); MFA manipulation in 12% of impacted organisations (Proofpoint)	No
A rogue device and Primary Refresh Token	Storm-2372 via the Authentication Broker (Microsoft, Feb 2025)	No: the device remains
An OAuth app or consent grant	Midnight Blizzard (Microsoft, Jan 2024); ConsentFix	No
Mailbox rules and forwarding	AiTM-to-BEC campaign (Microsoft, 2022); rules in 28% of impacted organisations	No
Reuse of Windows Hello keys	Research: from code in the user's session, without the PIN (Mollema, Aug 2026)	No



Eviction means removing what was added, not just changing the password.

All four routes, plus persistence

AROUND

THROUGH

AFTER

RESET

Route	Examples	What MFA saw	What closes it
AROUND	Change Healthcare, Snowflake, Midnight Blizzard	Nothing: not in the path	Provable coverage
THROUGH	Uber, Retool, Tycoon 2FA, EvilTokens, ConsentFix	A valid MFA by the real user, for the attacker	Phishing-resistant MFA, plus blocking device code and controlling consent
AFTER	Infostealers, Okta support breach	Nothing: the login had already happened	Session binding; endpoint hygiene
RESET	M&S, Scattered Spider	A valid MFA with the attacker's own factor	Recovery and enrolment as strong as the login
PERSIST (after any route)	Rogue devices, added MFA methods and Hello keys, app grants, mailbox rules	A valid MFA, even phishing-resistant, with the attacker's own key	Not MFA: restrict device and method registration, detect, evict



'More MFA' addresses part of one route, and none of the persistence.



CONTEXT

GET IN

GET OUT

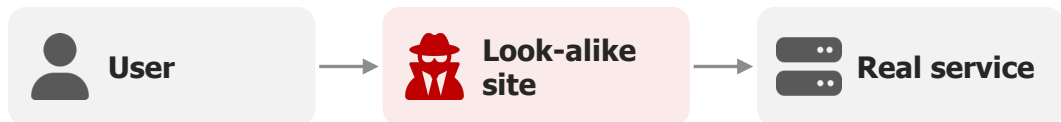
TAKEAWAYS

AROUND

THROUGH

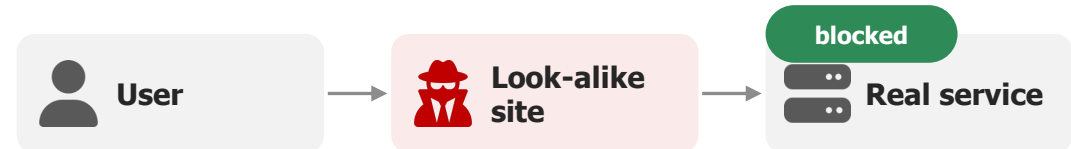
AFTER

RESET

Code or push **phishable**

1. User on the look-alike site types the password and code, or approves the push
2. The proxy forwards them to the real service within seconds
3. The real service sees a correct code; it cannot tell where it was typed

✗ **A code works wherever it is typed**

Passkey or FIDO2 **phishing-resistant**

1. The browser, not the user, tells the authenticator which site is asking
2. The key is scoped to the real domain: the look-alike site gets nothing usable
3. The signed response names the site; the real service rejects a mismatch

✓ **Nothing to type, approve or relay**

Definition (NIST SP 800-63B-4): the authenticator's output is bound to the site's name or to the session, so an impostor cannot reuse it. Passwords, codes and push approvals are not phishing-resistant.

Examples: passkeys · FIDO2 security keys · Windows Hello for Business · certificate-based authentication

Can a passkey be copied like a password? It is never typed or sent to the website, so phishing cannot capture it.

Device-bound (security key, Windows Hello for Business): never leaves the device. **Synced** (Apple, Google, password managers): copied to your devices, end-to-end encrypted, so protect that account.

 **Phishing-resistant means the user cannot hand the credential to the wrong site, even by mistake.**

GET OUT

Not all MFA is equal

AROUND

THROUGH

AFTER

RESET

Method	Password spray / stuffing	Push fatigue	Code relay by a caller	AiTM proxy	SIM swap	Device-code phishing
SMS or voice code	✓	—	✗	✗	✗	✗
Authenticator code (TOTP)	✓	—	✗	✗	✓	✗
Push + number matching	✓	⦿	✗	✗	✓	✗
Passkey, FIDO2, WHfB, certificate	✓	✓	✓	✓	✓	✗

✓ resists ⦿ partly ✗ does not resist — not applicable

Not stopped by any MFA method on its own: consent abuse · stolen sessions · help-desk resets · rogue devices · coverage gaps

 **Phishing-resistant MFA closes most of THROUGH. The other routes need different controls.**

International



NIST SP 800-63B-4 · Aug 2025

AAL2 must offer a phishing-resistant option; AAL3 must be phishing-resistant with a non-exportable key; SMS and voice remain 'restricted'



CISA, FBI, NCSC-UK and others · Jul 2025

Require phishing-resistant MFA for all services to the extent possible



Microsoft Entra

Microsoft-provided SMS and voice MFA retired: 1 Feb 2027 for most users, 1 Jul 2027 for Global Admins and external users



Mauritius

Bank of Mauritius guideline, May 2023

- MFA required for admin accounts on critical systems, internet access to customer data and all remote access
- Higher-risk e-channel transactions require MFA
- MFA defined as two or more factors; phishing resistance not specified

**An SMS code meets the definition.
Compliant is not the same as phishing-resistant.**



The direction is clear: phishing-resistant by default, starting with the most powerful accounts.

AROUND

THROUGH

AFTER

RESET

- ✓ Block legacy authentication protocols
- ✓ Put VPN, VDI and remote portals behind the identity provider with MFA
- ✓ Replace service-account passwords with workload identities, or restrict, vault and rotate them
- ✓ Retire test tenants, stale applications and dormant accounts
- ✓ Give every policy exclusion an owner and an expiry date
- ✓ Monitor infostealer and breach exposure; rotate exposed credentials



The metric that matters

Share of sign-ins, by application and path, that required phishing-resistant MFA

Not 'users registered for MFA', which counts people rather than the doors they use.



If you cannot list every way in, you cannot claim MFA covers them.

AROUND

THROUGH

AFTER

RESET

1**Administrators and break-glass**

FIDO2 or certificates; test break-glass every 90 days

2**High-risk roles**

Finance, HR, help desk, IT, executives and assistants

3**Everyone**

Passkeys: device-bound or synced, by risk

Make it stick**Enforce, don't just enable**

Require a phishing-resistant authentication strength on the apps and roles in scope

**Remove the fallbacks**

Otherwise the attacker simply picks the weakest method still allowed

**Plan recovery first**

e.g. Temporary Access Pass issued after strong identity checks



A strong method only counts if the weaker ones can no longer be used instead.

AROUND

THROUGH

AFTER

RESET



Device-code flow

- Conditional Access > Conditions > Authentication flows > Device code flow > Block
- Start in report-only; see who really uses it
- Allow only documented, secured exceptions



Application consent

- Restrict user consent to verified publishers and low-impact permissions
- Admin consent workflow with named reviewers
- Review existing grants, owners and app credentials



Developer and admin tools

- Monitor sign-ins to tools such as the Azure CLI by non-admin users
- Hunt non-interactive sign-ins from new IPs after an interactive one
- Restrict who can use admin tools, after testing



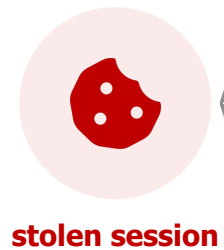
These flows issue tokens without the login page your users were trained to check.

AROUND

THROUGH

AFTER

RESET

**Bind to the device**

Entra Token Protection (native apps on Windows, macOS, iOS) · Chrome DBSC (Windows, on by default for Google accounts)

**Revoke and re-evaluate**

Continuous Access Evaluation: near real time, up to 15 min · shorter sign-in frequency for admins

**Require managed devices**

Compliant or managed device for sensitive apps; replay from attacker kit fails policy

**Keep stealers off endpoints**

EDR, application control, no personal browser profiles on corporate devices



Session binding finally targets cookie theft, but coverage is partial: pilot it, then measure what it covers.

AROUND

THROUGH

AFTER

RESET



Help desk

- Verify through an independent channel: call back on the number in the HR record
- Never reset MFA on the caller's word alone
- Two people for privileged resets: one approves, one executes
- Same rules for outsourced help desks; test with mystery calls
- Treat voice and video as spoofable



Enrolment

- Require strong conditions to register a factor or a device
- Temporary Access Pass, after verification, instead of SMS
- Alert on every new method and device registration
- Move off SMS to remove SIM-swap exposure



A reset should restore the verified owner's control, with the same assurance as the login it replaces.

AROUND

THROUGH

AFTER

RESET



Sign-ins

- Device-code sign-ins
- Unusual client apps for this user (e.g. Azure CLI, Authentication Broker)
- Token use from a new location or network



Identity changes

- New MFA method
- New device registration
- New consent grant or app credential
- New role assignment



Mailbox

- New inbox rules that hide or delete
- External forwarding
- Searches for invoices and payments



Endpoint

- Infostealer detected on a device with corporate sessions: treat it as an identity incident



Failed logins tell you about attempts. Successful ones, followed by changes, tell you about compromises.

AROUND

THROUGH

AFTER

RESET

1 Contain



Block sign-in; isolate the endpoint

2 Invalidate



Revoke sessions and refresh tokens; reset the password via a trusted channel

3 Remove



MFA methods, devices, consent grants, app credentials, mailbox rules, roles

4 Repair



Close the route that was used

5 Verify



Confirm access fails; monitor the account and related ones



Revoke-MgUserSignInSession -UserId user@example.com

Invalidates refresh tokens and browser session cookies. Access tokens already issued can stay valid until expiry, unless the service supports Continuous Access Evaluation.



The persistence attackers add survives a password reset. Remove it explicitly.

AROUND

THROUGH

AFTER

RESET

PHASE 1

- Block legacy authentication
- Device code: report-only, then block
- Restrict user consent
- Phishing-resistant MFA for admins and break-glass
- Help-desk verification procedure
- Hunt rogue methods, devices, grants

PHASE 2

- Phishing-resistant MFA for high-risk roles
- Compliant devices for sensitive apps
- Token Protection pilot
- Detections for identity changes
- Tested eviction runbook

PHASE 3

- Phishing-resistant MFA for everyone
- Retire SMS and voice
- Remove weak recovery paths
- Session binding across key SaaS

 **Entra deadline:** Microsoft-provided SMS and voice MFA retired 1 Feb 2027 (most users) and 1 Jul 2027 (Global Admins, external users)

 **Start with what is cheap and reversible; save what is disruptive for when it has been piloted.**

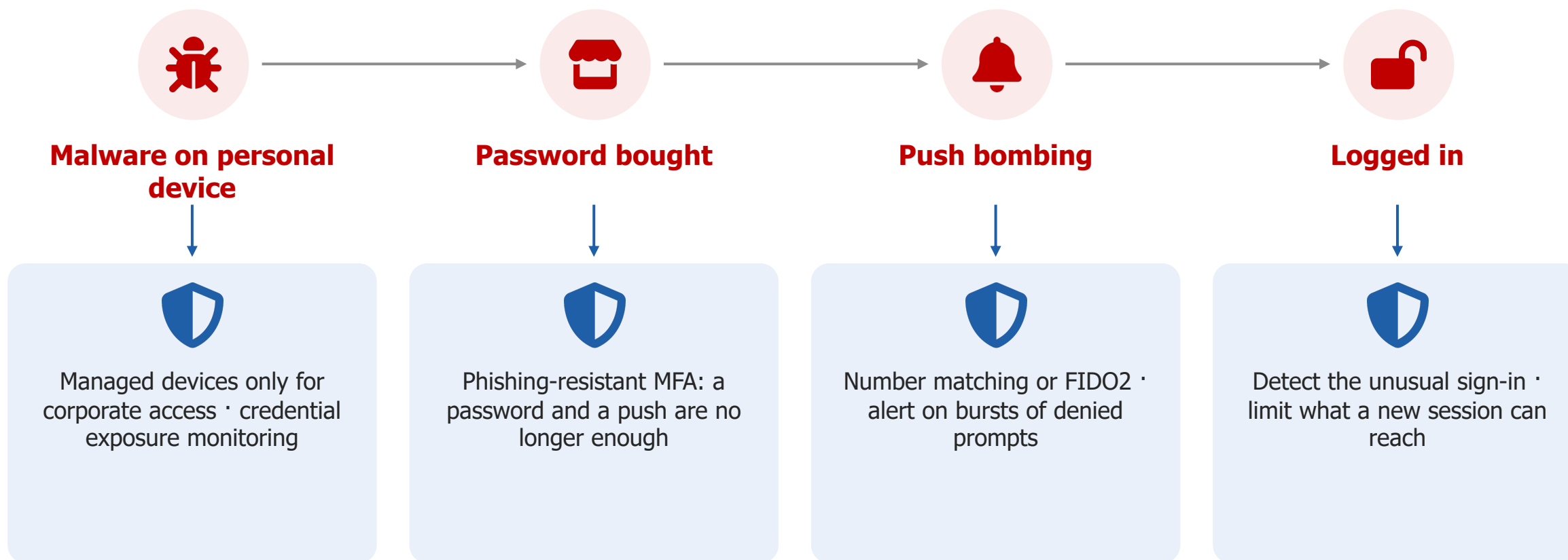


CONTEXT

GET IN

GET OUT

TAKEAWAYS



Illustrative analysis using today's controls; not a finding of Uber's investigation.



Only one of these four controls is 'MFA'. The others protect the moments around it.

1

MFA still works

Keep it everywhere: it stops the overwhelming majority of password attacks

2

Prove the coverage

Many 'bypasses' are accounts, apps or protocols outside the policy

3

Make it phishing-resistant

Codes and pushes relay; passkeys and certificates don't. Start with admins

4

Protect what MFA doesn't

Sessions, recovery, device-code and consent flows need their own controls

5

Plan the eviction

A password reset leaves the attacker's methods, devices, grants and rules in place



MFA protects one moment. Protect the moments around it too.



Which sign-ins in our estate do not require MFA today?

AROUND



Is the device-code flow allowed, and who actually uses it?

THROUGH



Can an ordinary user consent to an application on their own?

THROUGH



What does our help desk need before resetting MFA, and does our outsourcer do the same?

RESET



If a session token were stolen today, how long would it work, and would we notice?

AFTER



Have we ever tested evicting an attacker end-to-end?

ALL ROUTES

Incidents

- Uber security update, Sep 2022
- Retool, 'When MFA isn't actually MFA', Sep 2023
- Okta support system root cause, Nov 2023
- Change Healthcare: CEO Senate testimony, May 2024
- Mandiant, UNC5537 / Snowflake, Jun 2024
- Microsoft, Midnight Blizzard guidance, Jan 2024
- M&S: UK Business and Trade Committee, Jul 2025

Threat intelligence

- Microsoft: AiTM to BEC (Jul 2022); Storm-2372 (Feb 2025, upd. Jul 2026); EvilTokens (Sep 2026)
- Proofpoint: device code (Dec 2025); ATO analysis (Feb 2026); Tycoon 2FA (Mar 2026)
- CrowdStrike: Tycoon2FA after takedown (Mar 2026)
- SpyCloud 2026 Identity Exposure Report
- Microsoft and Europol: Lumma disruption (May 2025)
- Push Security: ConsentFix (Dec 2025)

Research and data

- Microsoft Research: MFA effectiveness (May 2023)
- Microsoft Digital Defense Report (Oct 2025)
- Dirk-jan Mollema: Windows Hello keys (Aug 2026)

Standards and guidance

- NIST SP 800-63B-4 (Aug 2025)
- Joint Scattered Spider advisory AA23-320A (Jul 2025)
- Bank of Mauritius Guideline on Cyber and Technology Risk Management (May 2023)
- RFC 6750 (bearer tokens), RFC 8628 (device grant)

Controls

- Microsoft Learn: SMS/voice retirement, authentication flows, Token Protection, CAE, authentication strengths, emergency access, session revocation
- Google: Device Bound Session Credentials (Apr and May 2026)

THANK YOU!

Any Questions?



ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY PROVIDES A PORTFOLIO OF **STRATEGIC** AND **TACTICAL SERVICES** TO HELP COMPANIES **PROTECT** AND **RESPOND** AGAINST **CYBER SECURITY THREATS**. WE DIFFERENTIATE OURSELVES BY OFFERING **DISCREET, TAILORED** AND **SPECIALIZED** ENGAGEMENTS.

ELYSIUMSECURITY OPERATES IN **MAURITIUS** AND IN **EUROPE**, A **BOUTIQUE STYLE** APPROACH MEANS WE CAN **EASILY ADAPT** TO YOUR BUSINESS OPERATIONAL MODEL AND REQUIREMENTS TO PROVIDE A **PERSONALIZED SERVICE** THAT FITS YOUR WORKING ENVIRONMENT.

ELYSIUMSECURITY PROVIDES **HIGH LEVEL EXPERTISE** GATHERED THROUGH YEARS OF **BEST PRACTICES EXPERIENCE** IN LARGE INTERNATIONAL COMPANIES ALLOWING US TO PROVIDE ADVICE BEST SUITED TO YOUR **BUSINESS OPERATIONAL MODEL** AND **PRIORITIES**.

ELYSIUMSECURITY PROVIDES **PRACTICAL EXPERTISE** TO **IDENTIFY VULNERABILITIES**, ASSESS THEIR **RISKS** AND **IMPACT**, **REMEDiate** THOSE RISKS, **PREPARE** AND **RESPOND** TO INCIDENTS AS WELL AS RAISE **SECURITY AWARENESS** THROUGH AN ORGANIZATION.

